

TokenOracleDEX

TokenOracleDEX.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	DEX simple: compra/venta de un token interno contra ETH usando un precio almacenado.
Actores	Cualquiera (setPrice/buy/sell). Sin admin real.
Flujo de fondos	buy() acumula balance segun price; sell() paga ETH segun price.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	setPrice sin control: manipulacion de precio Root: Oraculo de precio interno controlable por cualquier actor; sin control de acceso ni fuente fiable.	setPrice(p) es publica y sin restricciones; cualquiera fija el precio a voluntad antes de comprar o vender. Vector: Comprar con price bajo, subir price con setPrice y vender, extrayendo mas ETH del depositado hasta drenar el contrato.	Critical	SWC-105	SC03:2026 Price Oracle Manipulation
2	Reentrancy en sell() Root: Violacion de Checks-Effects-Interactions (interaccion antes del efecto).	sell() ejecuta el call de ETH ANTES de restar balances[msg.sender]. Un contrato malicioso reentra antes de la actualizacion del saldo. Vector: Reentrada recursiva en sell() para retirar repetidamente con el mismo saldo.	Critical	SWC-107	SC08:2026 Reentrancy
3	Division por cero y unidades inconsistentes Root: Modelo aritmetico/AMM inexistente; sin invariantes de liquidez.	sell() calcula amount/price; si price=0 revierte. buy multiplica y sell divide con unidades incoherentes respecto al ETH real, generando insolvencia. Vector: DoS por price=0 y descuadre contable entre balances y ETH disponible.	Medium	SWC-101	SC07:2026 Arithmetic Errors

3. Analisis de logica de negocio

Economicamente roto y drenable: el precio es manipulable por cualquiera y sell() es reentrante; la contabilidad no guarda relacion con el ETH custodiado.

6. Benchmark metrics

3	2	0	1	0	0.93	0.90	1.00	60	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).